ZOIKO SHIELD PLATFORM

Frontend Architecture & Complete Operator Journey Manual

Exhaustive Step-by-Step Operator Flow • Operational Justifications ('Why We Have Used This') • All 38 Cockpit Routes • ZS-EML-TPL-001 v2.0

1. Executive Frontend Architecture & System Justification

The Zoiko Shield frontend application is a sovereign, zero-trust cloud security workspace engineered on Next.js 14 App Router, React 18, TypeScript (strict typechecking), and Tailwind CSS. The interface serves multi-tenant enterprises, financial institutions, and defense operators who mandate cryptographic verification, non-repudiable audit logs, and strict human-in-the-loop AI governance.

EXECUTIVE RATIONALE — Why This Frontend Architecture Was Built

Modern cyber defense platforms frequently suffer from three systemic flaws: (1) ungrounded autonomous AI actions causing outages, (2) lack of cryptographic proof for audit events, and (3) cross-tenant data leakage in multi-tenant environments. Zoiko Shield solves this by enforcing Cedar fine-grained ABAC on every client route, mandatory §16.1 Decision Review Envelopes for AI actions, deterministic SHA-256 rendering of 226 contractual email notifications, and an immutable Merkle Evidence Ledger.

2. Global Context Bar & Multi-Tenant State Header

Visible at the pinnacle of every screen, the Global Context Bar anchors the operator's operational scope and security boundaries:

Header Badge Element	Live Runtime Value	Operational Justification ('Why We Use This')
Tenant Scope	Acme Financial Services Inc. [ENTERPRISE]	Guarantees that the session is strictly isolated to the authorized customer organization, preventing accidental cross-tenant queries.
Environment Tag	PRODUCTION-US-EAST	Prevents operators from confusing staging/sandbox test runs with live production infrastructure containment actions.
Sovereign Residency Cell	Region: eu-west-1	Ensures strict data residency compliance (GDPR / DORA) by verifying telemetry remains within the declared sovereign jurisdiction.
Evidence Ledger Status	Evidence: Signed Merkle Checkpoints	Continuously attests that the hourly Merkle tree root has been dual-signed with Post-Quantum KMS keys and anchored to Sigstore Rekor.
Microservices Fleet Health	Microservices: 5/5 OK	Monitors real-time heartbeats across shield-core, shield-ingest, shield-ai, shield-action, and shield-anchor.
Principal & Active Role	ANALYST OPS (SECURITY_ANALYST)	Binds user permissions to Cedar ABAC policies; prevents unprivileged execution of destructive containment playbooks.
BFF Experience Contract	HEALTHY_SYNCED | Live (0s drift)	Validates LAB 14 frontend-to-backend contract freshness, guaranteeing zero data staleness in streaming dashboards.

STEP 1: Identity & Zero-Trust Authentication (/login)

SECURITY JUSTIFICATION — Why We Have Used This Page

The /login interface is the non-negotiable zero-trust entrypoint for Zoiko Shield. Modern threat actors frequently compromise static credentials via phishing and credential stuffing. To satisfy SOC 2, ISO 27001, and NIST SP 800-63B standards, Zoiko Shield implements WebAuthn FIDO2 biometric passkeys alongside traditional credentials, coupled with dynamic Cedar ABAC claims hydration and strict multi-tenant boundary selection.

A. Screen Components & User Interface Layout

• **Tenant Selector Dropdown:** Allows the operator to choose their target organization (e.g. Acme Financial Services Inc., sovereign-defense-cell), which binds the x-tenant-id header to every subsequent HTTP request.
• **WebAuthn FIDO2 Passkey Button:** Prompts the operating system's hardware authenticator (TouchID, Windows Hello, YubiKey) for biometric sign-in.
• **Password & Email Fields:** Standard credential inputs backed by rate-limiting (max 5 failed attempts per 15 minutes before temporary lockout).
• **Quick Demo Persona Pills:** Pre-configured persona selectors (SOC Analyst, Security Officer, Platform Admin) that permit rapid validation of role-based view permissions during audits without manual credential typing.

B. Step-by-Step Operator Interaction & Data Flow

1. **Operator Navigation:** The analyst navigates to https://shield.zoiko.internal/login.
2. **Tenant Selection:** The user selects their sovereign tenant. If omitted, the default primary workspace is bound.
3. **Credential Submission:** The user clicks 'Sign In with Passkey' or enters email/password. The browser invokes ZoikoShieldApiClient.login().
4. **Backend Verification:** shield-core verifies credentials, queries Cedar authorization engine for role grants, and issues an ephemeral JWT.
5. **State Hydration:** The frontend stores the token in secure memory (never in localStorage to prevent XSS exfiltration) and populates the Global Context Bar.
6. **Error Handling:** If authentication fails or the tenant is disabled, the page transitions to UnauthorizedState with detailed Cedar rationale.

C. Data Contracts & Microservice Endpoints Involved

HTTP Method & Endpoint	Payload Contract	Handling Microservice & Security Gate
POST /api/v1/auth/login	{ email, password, tenantId, fidoAssertion }	shield-core • Gate 1: Cedar Principal Validation & Rate Limiter
POST /api/v1/auth/passkey/challenge	{ email, tenantId }	shield-core • Generates random 32-byte cryptographic challenge

STEP 2: Tenant Workspace Onboarding (/onboarding)

REGULATORY JUSTIFICATION — Why We Have Used This Page

Multi-tenant defense platforms cannot rely on generic user registration. Every tenant represents a legally sovereign entity with mandatory cryptographic data boundaries, regional residency requirements (e.g. EU GDPR, US FedRAMP), and data classification levels. The /onboarding page guarantees that new organizations establish strict PostgreSQL Row-Level Security (RLS) schemas, provision Cloud KMS encryption keyrings, and register root compliance contacts before any security telemetry is ingested.

A. Screen Components & Configuration Fields

• **Organization Name & Slug:** Canonical enterprise identifier (e.g., 'Acme Financial Services', slug: 'acme').
• **Legal Entity Name:** Legal registrant used for compliance disclosure contracts and billing invoices.
• **Sovereign Residency Cell:** Selectable geographic processing cells (us-east-1, eu-central-1, ap-southeast-1) which pins all Kafka streams and PostgreSQL storage to that specific cloud region.
• **Data Classification Selector:** Sets the baseline sensitivity (PUBLIC, INTERNAL, CONFIDENTIAL, RESTRICTED).
• **Order Reference Identifier:** Cryptographically generated unique onboarding order ID (ord-enterprise-XXXX).

B. Step-by-Step Operator Interaction & Provisioning Flow

1. **Navigation:** Administrator accesses https://shield.zoiko.internal/onboarding.
2. **Input Completion:** Administrator enters company details, chooses RESTRICTED classification, and selects residency region.
3. **Order Issuance:** Frontend validates inputs against regex schemas and displays order confirmation banner.
4. **Provisioning Dispatch:** User clicks 'Complete Sovereign Provisioning'. Frontend dispatches POST /api/v1/organizations/onboard.
5. **Backend Execution:** shield-core creates tenant record, binds PostgreSQL RLS policy, requests tenant signing key from Cloud KMS, and initializes empty Merkle tree leaf node.
6. **Automatic Redirection:** On completion, the frontend switches tenant context to the new organization and redirects the administrator to the Command Overview Cockpit (/).

C. Data Contracts & Microservice Endpoints Involved

HTTP Method & Endpoint	Payload Contract	Handling Microservice & Security Gate
POST /api/v1/organizations/onboard	{ name, slug, legalEntity, residencyRegion, classification, orderId }	shield-core • Gate 3: Tenant Isolation Boundary & Cloud KMS Provisioner

STEP 3: SecOps Command Center & Operational Cockpit (/)

SOC OPERATIONAL JUSTIFICATION — Why We Have Used This Page

The primary dashboard (/) is the centralized nerve center for the Security Operations Center (SOC). In high-threat environments, analysts cannot afford to navigate multiple fragmented tools to assess risk posture. This cockpit provides a unified, real-time single-pane-of-glass displaying posture health, active P0 alerts, AI safety guardrail status, active ingestion health, and continuous compliance adherence.

A. Screen Components & Key Operational Widgets

• **Master Posture Score (99.98% Healthy):** Weighted aggregate score computing vulnerability density, open incident duration, and connector uptime.
• **AI Safety Guardrail Warning Banner:** Displays active guardrail state (e.g. 'AI Safety Guardrail Degraded (Deterministic Rule Engine Active)'). Informs analysts that Vertex AI LLMs are operating in fail-safe fallback mode due to detected drift, routing response proposals through deterministic rule evaluators.
• **KPI Metric Cards:**
- *Unresolved Alerts:* 4 active alerts (5 total detected) requiring operator triage.
- *AI Safety & Drift:* 1 active drift anomaly linked to AI Copilot and SOAR response proposals.
- *Active Connectors:* 6 connectors reporting 100% ingestion health across AWS, Azure, and CrowdStrike.
- *Compliance Posture:* 100% Pass across SOC 2 Type II, ISO 27001, and DORA controls.
• **Action Buttons:**
- *AI Safety Cockpit:* Opens the AI Governance drawer to inspect Model Armor screening and killswitch toggles.
- *Simulate Telemetry:* Injects synthetic security event bursts into Kafka for live demonstration and drill exercises.

B. Step-by-Step Operator Interaction & Real-Time Flow

1. **Page Load & SSE Handshake:** Frontend establishes Server-Sent Events (SSE) connection to GET /api/v1/telemetry/stream.
2. **Live Metric Rendering:** KPI cards update dynamically every 1,000ms with zero page reload.
3. **Alert Notification:** When an ingestion burst occurs, an animated badge flashes on the 'Unresolved Alerts' card.
4. **Drill-Down Trigger:** Clicking 'Unresolved Alerts' redirects the operator directly to the Alerts Cockpit (/alerts) with pre-applied P0 severity filters.

STEP 4: ERB-01 Demonstration Runbook Workflow (10 Stages)

RUNBOOK ARCHITECTURE — Why We Have Used This Runbook

Standard Operating Procedures (SOPs) often fail because they exist as static PDFs rather than live, verifiable software workflows. The ERB-01 Runbook bar (anchored at the footer of the Command Cockpit) is an interactive demonstration and training engine that steps operators through all 10 stages of the platform's multi-microservice defense grid, validating live contracts across shield-core, shield-ingest, shield-ai, shield-action, and shield-anchor.

Stage #	Stage Title	Microservice	Operational Action & Live Contract Verification
1	Ingestion Heartbeat	shield-ingest	Validates connector health, buffer latency, and OPS-INV-13 liveness signals.
2	OCSF Normalization	shield-ingest	Validates raw telemetry mapping to OCSF v1.1.0 (normalization files preserved untouched).
3	Asset Inventory Matching	shield-core	Correlates IP and MAC addresses against the sovereign CMDB asset database.
4	Cloud Armor WAF Sync	shield-action	Checks perimeter firewall rule synchronization and blocklist capacities.
5	Threat Intel IOC Match	shield-core	Pivots extracted hashes and IPs against global STIX/TAXII threat intelligence.
6	Detection & Alerting	shield-core	Executes threshold detection rules, generating correlated P1/P0 security alerts.
7	AI Copilot §16.1 Synthesis	shield-ai	Vertex AI synthesizes 10-field Decision Envelope with hallucination risk interval.
8	4-Eyes Cedar Ratification	shield-core	Cedar policy engine mandates dual-custody approval before containment authorization.
9	SOAR Action Execution	shield-action	Executes endpoint quarantine with guaranteed compensating rollback staging.
10	Merkle Root Epoch Sealing	shield-anchor	Computes domain-separated Merkle root, signs with Cloud KMS, anchors to Sigstore Rekor.

Operator Control: Operators click 'Next Stage >' to advance through the runbook. A green pill ('All Steps Verified') illuminates once Stage 10 anchors the cryptographic receipt.

STEP 5: Ingestion Fleet & Connectors Wizard (/ingestion, /connectors)

INGESTION INTEGRITY — Why We Have Used These Pages

A SIEM/SOAR platform is only as trustworthy as its telemetry ingress. Ingestion failures or unhandled schema drifts lead to blind spots. The /connectors and /ingestion workspaces allow security engineers to provision cloud log connectors (AWS, Azure, Okta, CrowdStrike), monitor Events Per Second (EPS), track Dead-Letter Queues (DLQ), and inspect quarantined schema-mismatched records.

A. Screen Components & Ingestion Monitoring

• **Connector Grid:** Cards for AWS CloudTrail, CrowdStrike Falcon, Okta SystemLog, Microsoft Sentinel, and Azure Monitor.
• **OPS-INV-13 Heartbeat Monitor:** Live status indicator tracking connector polling cycles. If a connector drops below 1 poll/minute, an automated P1 operational alert is raised.
• **Throughput Velocity Charts:** Real-time EPS ingestion graphs visualizing 100,000 EPS peak capacity.
• **Dead-Letter Queue (DLQ) Inspector:** Table displaying malformed events with payload diffs, error messages, and an 'Auto-Retry' button.

B. Step-by-Step Operator Interaction & Provisioning

1. **Add Connector:** Engineer clicks '+ Add Connector' on /connectors.
2. **Select Source:** Chooses 'AWS CloudTrail' and specifies IAM Role ARN and SQS Queue URL.
3. **Validate Credentials:** Clicks 'Test Connection'. shield-ingest assumes the role and polls a test batch.
4. **Activate Ingestion:** On success, connector status shifts to 'HEALTHY_SYNCED' and telemetry streams to Kafka topic telemetry.raw.aws.
5. **Schema Normalization:** Telemetry is normalized by apps/shield-ingest/src/normalization/ into standard OCSF v1.1.0.

C. Data Contracts & Microservice Endpoints Involved

HTTP Method & Endpoint	Payload Contract	Handling Microservice & Security Gate
GET /api/v1/connectors	Headers: x-tenant-id	shield-ingest • Returns active connector inventory and heartbeat status
POST /api/v1/connectors/test	{ connectorType, credentials, endpoint }	shield-ingest • Validates connectivity without persisting credentials to disk

STEP 6: Detection Stream & Alerts Cockpit (/detections, /alerts, /alerts/[alertId])

ALERT TRIAGE EFFICIENCY — Why We Have Used These Pages

Security analysts face alert fatigue. Displaying hundreds of raw alerts without context causes missed intrusions. The /alerts and /detections interfaces ingest OCSF-normalized security events, group them using MITRE ATT&CK; techniques, evaluate Sigma and YARA-L detection rules, and provide deep drawer inspection with one-click escalation to Incident Casework.

A. Screen Components & Visual Triage Feed

• **Severity Badges:** Distinct visual indicators (P0 CRITICAL in crimson, P1 HIGH in amber, MEDIUM in blue, LOW in slate).
• **MITRE ATT&CK; Attribution:** Displays tactic and technique IDs (e.g. T1078 Valid Accounts, T1059 Command and Scripting Interpreter).
• **Affected Cloud Asset:** Shows hostnames, AWS EC2 Instance IDs, or Kubernetes pods linked to the sovereign CMDB.
• **Alert Inspection Drawer:** Sliding right-hand drawer revealing:
- Raw OCSF v1.1.0 JSON payload.
- Detection Rule Logic (Sigma YAML / YARA-L expression).
- Correlated Indicators of Compromise (IOCs).
- Action Buttons: 'Escalate to Incident Case', 'Consult AI Copilot', 'Suppress with Exception'.

B. Step-by-Step Operator Interaction & Casework Escalation

1. **Feed Monitoring:** Analyst reviews the alerts table, sorting by P0 Critical.
2. **Drawer Opening:** Analyst clicks on alert alt-ec2-credential-exfil-992.
3. **Payload Inspection:** Verifies the source IP against known adversary threat actor infrastructure.
4. **Case Escalation:** Clicks 'Escalate to Incident Case'. The system creates Case case-2026-10-0042 and opens the Case Workspace.
5. **Audit Trail:** An alert transition event (ZS-EML-SEC-010 Case created from alert/hunt) is recorded in the Merkle Ledger.

STEP 7: AI Security Copilot & AI Governance (/copilot, /ai-governance)

AI SAFETY INVARIANT — Why We Have Used These Pages

Generative AI provides unprecedented speed in correlating threat signals, but unconstrained LLMs introduce catastrophic risks: hallucinated facts, prompt injection attacks, and ungrounded advice. The /copilot and /ai-governance screens implement Google Vertex AI (Gemini 1.5 Pro) with strict Model Armor screening, calibrated confidence intervals, and emergency killswitches that instantly degrade the model to deterministic rule engines.

A. AI Copilot 6 Operating Modes

Mode	Operational Focus	Model Armor & Safety Guardrails
1. Triage	Rapid classification of high-volume alert queues.	Input token sanitization; scrubs PII and passwords.
2. Investigation	Graph-based correlation across multi-cloud logs.	Strict grounding against ingested OCSF telemetry only.
3. Lateral Movement	Reconstructs adversary pivot paths across IAM & VPCs.	Validates path reachability against network ACLs.
4. Code Analysis	Reverse-engineers suspect PowerShell & bash scripts.	Executes in sandboxed isolated worker container.
5. IOC Extraction	Extracts IPs, domains, and SHA-256 hashes from unstructured text.	Regex verification before database attachment.
6. Attribution	Correlates adversary TTPs against MITRE ATT&CK; groups.	Flags low-confidence attribution (<85%) with explicit disclaimer.

B. AI Governance Cockpit & Safety Killswitch

• **AI Drift Monitor:** Tracks model divergence from deterministic rule baselines.
• **Emergency AI Killswitch:** Toggling 'AI_GOVERNANCE_KILL_SWITCH_ACTIVE' immediately revokes LLM API keys and forces the entire platform into safe degradation mode (Deterministic Rule Engine).

STEP 8: Response Proposals (W34) & Mandatory §16.1 Envelopes (/response-proposals)

MANDATORY GOVERNANCE GATE — Why We Have Used This Page (Spec §16.1 Compliance)

CRITICAL ARCHITECTURAL RULE: An AI model must NEVER be permitted to execute autonomous containment actions without explicit human operator ratification. Doing so risks catastrophic service outages and uncontainable blast radiuses. Under Platform Spec §16.1 & Figure 11, any remediation recommended by Vertex AI must be packaged inside a mandatory 10-Field Decision Review Envelope and ratified by a human operator using cryptographic signatures.

A. The 10-Field Decision Review Envelope Specification

Field #	Envelope Field Name	Type / Format	Engineering Purpose & Regulatory Invariant
1	proposal_id	UUIDv4	Unique idempotent identifier for tracking the proposal across microservices.
2	model_version	String (vertex-gemini-1.5)	Exact model and prompt template hash used to generate the recommendation.
3	hallucination_probability	Float (0.00 - 1.00)	Calibrated confidence metric; proposals > 0.15 require Tier-2 senior operator sign-off.
4	action_type	Enum (ALLOWLISTED)	Must be an approved action: ISOLATE_HOST, BLOCK_IP, REVOKE_SESSION.
5	target_infrastructure	Array of Resource URIs	Exact CMDB assets affected (e.g. arn:aws:ec2:us-east-1:123456:instance/i-0abc).
6	blast_radius_estimate	Enum (LOW/MED/HIGH/CRIT)	Estimated operational impact on active customer business traffic.
7	technical_justification	String (Markdown)	Synthesized reasoning explaining why this action halts the adversary.
8	compensating_rollback_plan	Executable JSON Spec	Exact reverse action guaranteed to restore the asset if containment was erroneous.
9	expiry_window	ISO 8601 Timestamp	Proposal auto-expires within 30 minutes if unratified to prevent stale action execution.
10	operator_ratification_signature	ECDSA / Ed25519 Sig	Cryptographic signature of the human operator approving the action.

B. Human Operator Ratification Workflow

1. Analyst opens /response-proposals and selects pending proposal.
2. Modal prompts for mandatory operator written rationale (minimum 20 characters).
3. Operator clicks 'Ratify & Dispatch'. Frontend submits cryptographic signature to shield-action.

STEP 9: SOAR Containment Actions & Emergency Freeze (/actions, /playbooks)

SOAR RELIABILITY INVARIANT — Why We Have Used These Pages

When active breaches unfold, seconds determine whether ransomware spreads across the enterprise. Manual remediation through multiple cloud consoles is too slow and error-prone. The /actions and /playbooks workspaces provide deterministic, automated containment execution (SOAR) with two critical fail-safes: (1) guaranteed atomic compensating rollbacks and (2) an Emergency Action Freeze killswitch.

A. Containment Actions Registry & Actuator Fleet

• **Host Quarantine:** Calls cloud provider APIs (AWS Security Group revoke, Azure NSG deny, CrowdStrike Network Contain) to isolate the infected endpoint from all network traffic except the Zoiko Shield agent.
• **IP Perimeter Block:** Pushes dynamic IP deny rules to Google Cloud Armor and AWS WAF.
• **Credential Revocation:** Revokes compromised Okta and Azure AD user sessions, forcing immediate sign-out.
• **IAM Policy Detachment:** Strips administrative permissions from compromised service accounts.

B. Emergency Action Freeze Killswitch (Levels R0 - R4)

In the event of adversary deception, rule misconfiguration, or cloud provider API flapping, operators can engage the global **Emergency Action Freeze** toggle. Engaging the freeze immediately locks the SOAR execution broker (shield-action), rejecting all inbound execution requests and notifying leadership via email template ZS-EML-ACT-010 Tenant action freeze activated.

C. Compensating Rollback Guarantee

Every containment action is paired with an idempotent rollback script. If an operator isolates an essential production database server by mistake, clicking 'Rollback Action' executes the compensating script, restoring original firewall rules in under 3.5 seconds.

STEP 10: Threat Hunting Workbench & Case Management (/hunting, /cases, /cases/[caseId])

INVESTIGATION GOVERNANCE — Why We Have Used These Pages

Advanced Persistent Threats (APTs) often evade standard signature-based detection rules. The /hunting and /cases cockpits provide forensic analysts with a hypothesis-driven ReAct query workbench and formal incident case management. Every evidence item, forensic timeline entry, and analyst note is cryptographically linked to prevent tampering or spoliation of legal evidence.

A. Threat Hunting Workbench Features

• **ReAct Query Builder:** Combines natural language questions with structured SQL/Sigma pivots.
• **Graph Link Explorer:** Visualizes entity relationships between compromised user accounts, infected VMs, and external command-and-control (C2) IP addresses.
• **IOC Sweeper:** One-click sweep that scans 90 days of cold storage telemetry for newly discovered adversary hashes.

B. Incident Case Workspace (/cases/[caseId])

• **Authoritative Incident Timeline:** Reconstructs every adversary action in chronological order.
• **Evidence Locker:** Attaches raw PCAP files, memory dumps, and disk image hashes. Raw evidence is hashed using SHA-256 and anchored to the Merkle Ledger.
• **SLA & Milestone Tracker:** Monitors Mean Time to Acknowledge (MTTA) and Mean Time to Contain (MTTC). Approaching SLA breaches trigger template ZS-EML-SEC-013 Case SLA approaching breach.

STEP 11: Policy Governance & 4-Eyes Lifecycle (/policies, /controls, /compliance)

4-EYES GOVERNANCE — Why We Have Used These Pages

Security policies govern access to sensitive data and control automated response thresholds. A single malicious or accidental policy modification could disable defenses or grant unauthorized privileges. The /policies cockpit implements strict Cedar policy authoring with mandatory 4-Eyes dual-custody review, canary deployment staging, and automated rollback if anomaly rates exceed thresholds.

A. Dual-Custody 4-Eyes Workflow (Step-by-Step)

1. **Policy Authoring:** Policy Admin drafts a new Cedar authorization rule (e.g. restricting SOAR containment to SOC tier 2).
2. **Diff Review:** Frontend displays visual diff between active policy version (v3) and proposed version (v4).
3. **Dual-Approval Gate:** The author cannot self-approve. The policy transitions to 'PENDING_SECOND_APPROVAL'.
4. **Second Approver Sign-off:** A second administrator receives email ZS-EML-ACT-003 Dual-custody / second approval requested, reviews the diff, and provides FIDO2 biometric confirmation.
5. **Canary Staging:** The policy is deployed to 10% of ingestion nodes for 1 hour.
6. **Full Rollout or Rollback:** If zero anomalies are reported, the policy promotes to 100% production. If false positives spike > 1%, the engine triggers an immediate atomic rollback to v3.

B. Continuous Controls & Compliance Mapping

The /controls and /compliance pages continuously evaluate live infrastructure against SOC 2 Type II, ISO 27001, DORA, and HIPAA controls. Failing controls immediately trigger template ZS-EML-ASSURE-001 Control status changed to failing/non-compliant state.

STEP 12: Merkle Evidence Ledger & Transparency Log (/ledger, /evidence-operations)

CRYPTOGRAPHIC INTEGRITY — Why We Have Used These Pages

In high-stakes regulatory audits and legal disputes, internal database logs are dismissed as self-serving because database administrators can alter records retroactively. To guarantee mathematical tamper-evidence, Zoiko Shield anchors all state transitions, alert decisions, and policy approvals into a domain-separated cryptographic Merkle Tree (ZS-MERKLE-V1) and publishes epoch witness roots to public Sigstore Rekor transparency logs.

A. Merkle Tree Architecture & Epoch Sealing

• **Leaf Node Construction:** Each audit event is serialized into canonical JSON and hashed: Leaf_Hash = SHA-256('ZS-LEAF-V1' || Event_Data).
• **Hourly Epoch Sealing:** Every 3,600 seconds, shield-anchor seals the epoch, computes the Merkle Root, and signs it using Google Cloud KMS HSM keys with Post-Quantum Dilithium3 + Ed25519 dual-signatures.
• **Sigstore Rekor Publication:** The signed root is published to the public Rekor transparency log, creating an immutable timestamped receipt.

B. Merkle Ledger UI Explorer (/ledger)

• **Epoch Visualizer:** Interactive tree graph displaying epoch roots, tree depths, and leaf counts.
• **Inclusion Proof Validator:** Operators enter any event ID (e.g. evt-alert-contain-1002) and click 'Verify Proof'. The UI reconstructs the audit path in real-time, verifying that the mathematical hash matches the public Rekor witness root.
• **Offline Proof Package Download:** Exports a self-contained .proof.json bundle allowing independent offline verification.

STEP 13: Production Email Template Studio (/admin/email-templates)

NOTIFICATION SECURITY — Why We Have Used This Page (Contract ZS-EML-TPL-001 v2.0)

Email notifications in cybersecurity platforms are high-risk attack surfaces: phishing lures, credential leaks, and notification noise can devastate operations. The /admin/email-templates studio implements the authoritative engineering baseline for all 226 contractual production email templates across 16 domains, enforcing 5 strict engineering release gates, deterministic SHA-256 render hashing, fail-closed secret scrubbing, and multi-tenant URL allowlisting.

A. Studio Capabilities & Inspection Features

• **226 Template Catalog:** Filterable by 16 operational domains (SEC, IAM, ORG, CONN, POL, ACT, INC, REP, BIL, SUB, AUD, DIS, DRI, OFF, OPS, GOV).
• **Live Multipart Render:** Renders simultaneous HTML and plain-text output with Dark/Light theme toggles and Mobile/Desktop viewport emulation.
• **Deterministic SHA-256 Render Hashing:** Displays live SHA-256 digest of the rendered HTML payload, providing a non-repudiable audit fingerprint.
• **Test Secret Gate:** Button that simulates accidental secret injection (e.g. API keys, passwords); confirms the engine fails-closed and sanitizes the output.
• **Live Verification Test Dispatch:** Sends a live test email directly to designated administrator mailboxes.

B. The 5 Engineering Release Gates (ZS-EML-TPL-001)

Gate #	Release Gate Standard	Enforcement Logic in Codebase
Gate 1	Completeness (226/226)	All 226 template contracts implemented; zero unmapped event IDs.
Gate 2	Allowlisted Enums	template-enums.registry.ts maps raw state strings to customer-safe labels.
Gate 3	Tenant Isolation	tenant-isolation-validator.service.ts rejects cross-tenant URLs and non-HTTPS links.
Gate 6	Fail-Closed Secret Sanitization	Automated regex inspection strips passwords, API keys, and bearer tokens.
Gate 9	Sender Class Reputation Router	sender-class-router.service.ts routes traffic across 8 isolated reputation mailboxes.

STEP 14: Notification Center (W04) & Delivery Tracking (/notifications)

DELIVERY ASSURANCE — Why We Have Used This Page

In high-severity security operations, sending an email is not enough; the security platform must guarantee delivery receipt and human operator acknowledgement. The /notifications center implements Experience Contract W04, displaying an outbox of all tenant delivery attempts, dead-letter statuses, and operator acknowledgement buttons that record compliance evidence.

A. Screen Components & Outbox Table

• **Delivery Outbox Table:** Displays timestamp, recipient email, subject line, sender class (e.g. security_sender), delivery status (DELIVERED, DEAD_LETTERED, PENDING, BOUNCED), and acknowledgement status.
• **Filter by Status & Sender Class:** Enables rapid triage of failed dispatches.
• **Operator Acknowledgement Actions:** Clicking 'Acknowledge' records a cryptographic timestamp proving the operator reviewed the notice.
• **Delivery Diagnostics Drawer:** Inspects SMTP response codes (e.g. 250 OK Message accepted for delivery) and render hashes.

B. Step-by-Step Operator Interaction & Inbound Webhooks

1. Security event occurs (e.g. P0 Alert).
2. shield-core renders email, writes record to NotificationDelivery table with status PENDING.
3. Dispatcher transmits message via SMTP relay. Status updates to DELIVERED.
4. Webhook listener (POST /api/v1/webhooks/notification-delivery) ingests SMTP delivery confirmation.
5. Operator opens /notifications, views the alert delivery, and clicks 'Acknowledge'.
6. Backend records acknowledgement in audit log, fulfilling DORA and SOC 2 notification compliance.

STEP 15: JIT Elevation Quorum (§13) & G1 Launch Gate Protocol (/admin/jit, /admin/g1-gate)

PRIVILEGE GOVERNANCE — Why We Have Used These Pages

Standing administrative privileges are the primary target for lateral movement. Under Zero-Trust Architecture, no user should hold permanent administrative rights. The /admin/jit interface implements Just-In-Time (JIT) privileged escalation with FIDO2 biometric step-up and multi-party quorum, while /admin/g1-gate enforces pre-flight production release readiness.

A. JIT Privileged Elevation Quorum (§13)

- **Time-Bounded Grants:** Elevations automatically expire after a configurable duration (default: 60 minutes).
- **Biometric Step-Up:** Requesting elevation triggers a hardware FIDO2 passkey challenge to prevent session hijacking.
- **Multi-Party Approval:** Requires two distinct security officers to ratify break-glass requests.
- **Automatic Revocation:** Upon expiration, Cedar ABAC claims immediately drop back to standard analyst privileges.

B. G1 Launch Gate Protocol & GTM Pre-Flight Checklist

The /admin/g1-gate and /admin/gtm-checklist dashboards track production readiness across 12 mandatory criteria: TypeScript typecheck, Swagger OpenAPI coverage, Controller Access tests, Capability Claims validation, Zero ungrounded terminology, Vitest suites (80/80 passed), and offline Merkle verifier attestation. All gates must show 'PASS' before production releases are authorized.

STEP 16: Platform Service Health & Independent Auditor Portal (/admin/platform-health, /auditor)

COMPLIANCE & RESILIENCE — Why We Have Used These Pages

Continuous service availability and transparent third-party auditability are paramount for sovereign cyber defense platforms. The /admin/platform-health cockpit monitors distributed microservices health, latency budgets, and failover drills (§31/§32), while the /auditor portal provides external compliance officers with a read-only, cryptographically verified evidence environment.

A. Platform Service Health Cockpit (§31/§32)

• **Microservices Telemetry:** Real-time health gauges for shield-core, shield-ingest, shield-ai, shield-action, and shield-anchor.
• **Disaster Recovery (DR) Drills:** Triggers simulated regional cell failover exercises (RTO < 30s, RPO = 0s).
• **Capacity Gauges:** Evaluates Kafka partition lag, PostgreSQL connection pool saturation, and Redis cache hit ratios.

B. Independent Auditor Portal (/auditor)

• **Read-Only Evidence Dossier:** External auditors review continuous control mappings (SOC 2, ISO 27001, DORA) without administrative access.
• **Offline Cryptographic Verifier:** Auditors can download the standalone verifier-cli binary and verify the complete audit trail on an air-gapped laptop with zero network dependencies.